

Mistrusted Advisor: When AWS Tooling Leaves Public S3 Buckets Undetected

Jason Kao, Fog Security

fwd:CloudSec Europe 2025

About Me



Jason Kao

Founder, Fog Security

Agenda

- 1 Finding Overview
- 2 Trusted Advisor Background
- 3 The Complexity of S3 and S3 Access
- 4 Technical Walkthrough
- 5 Aftermath & Response
- 6 Summary

Finding Overview



Security issues discovered with AWS Trusted Advisor's S3 security checks

When Trusted Advisor is denied access to scan an S3 bucket's security configuration, the S3 bucket will be evaluated incorrectly.



Ability to create public S3 buckets without detection

We were able to configure publicly accessible S3 buckets via ACLs and bucket policies without flagging Trusted Advisor.



Trusted Advisor Inaccurate Reporting

Trusted Advisor "ignores" these buckets and thus the overall S3 security check will report as secure. This can allow for data exfiltration from misconfiguration or malicious internal actors.



Amazon S3 Bucket Permissions

Checks buckets in Amazon Simple Storage Service (Amazon S3) that have open access permissions or allow access to any authenticated AWS user.

0 of 1 buckets have permission properties that grant global access.

Last updated: 3 minutes ago

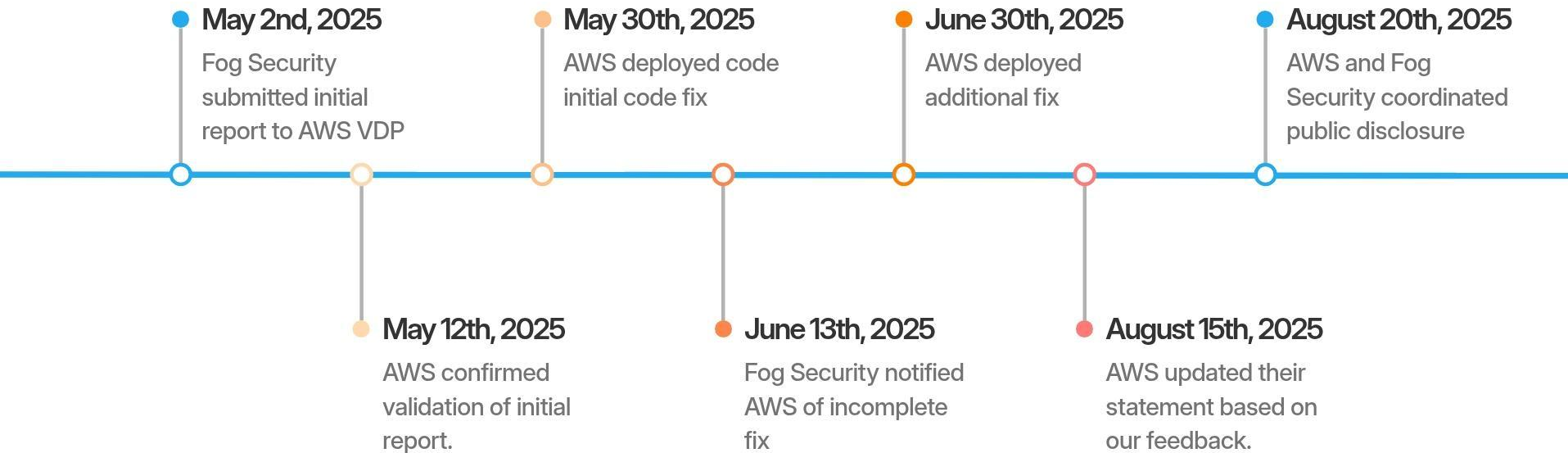


Finding Details: The Payload

We discovered 3 distinct scenarios where Trusted Advisor's alerting could be bypassed and would not alert on Public Buckets. This included the creation of a bucket policy that blocked Trusted Advisor from at least 1 of the following 3 actions:

- **s3:GetBucketACL**
Grants permission to use the acl subresource to return the access control list (ACL) of an Amazon S3 bucket
- **s3:GetBucketPolicyStatus**
Retrieves the policy status for an Amazon S3 bucket, indicating whether the bucket is public.
- **s3:GetBucketPublicAccessBlock**
Grants permission to retrieve the PublicAccessBlock configuration for an Amazon S3 bucket

Timeline of Disclosure and Resolution

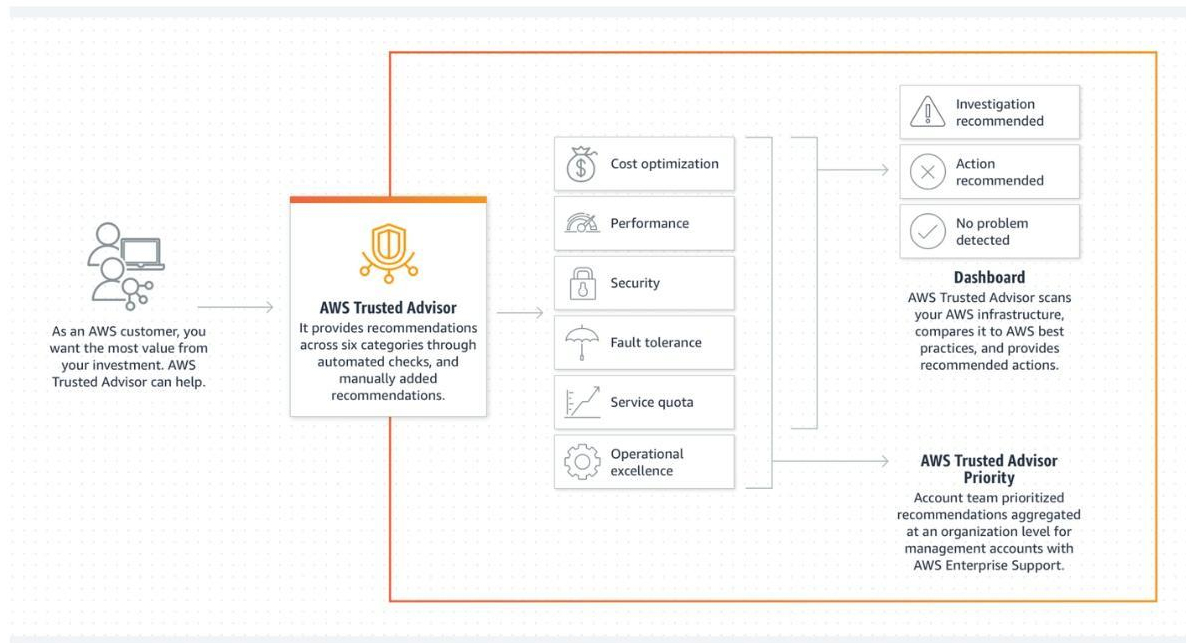




AWS Trusted Advisor

AWS Trusted Advisor

AWS Trusted Advisor is one of AWS's Management & Governance Services that provides recommendations across multiple categories including security. One of these checks is the S3 Bucket Permissions security check, which checks buckets for public access.



Plans	Developer Support	Business Support	Enterprise On-Ramp	Enterprise
AWS Trusted Advisor Best Practice Checks	Service Quota and basic Security checks	Full set of checks	Full set of checks	Full set of recommended checks. AWS a Trusted Advisor

AWS Support, 2025



Note

If you have a Basic Support and Developer Support plan, you can use the Trusted Advisor console to access all checks in the [Service limits](#) category and the following checks in the Security and Fault Tolerance categories:

- [Amazon EBS Public Snapshots](#)
- [Amazon RDS Public Snapshots](#)
- [Amazon S3 Bucket Permissions](#)
- [MFA on root account](#)
- [Security Groups – Specific Ports Unrestricted](#)
- [AWS STS global endpoint usage across AWS Regions](#)

AWS Trusted Advisor Documentation, 2025

Amazon S3 Bucket Permissions

Description

Checks buckets in Amazon Simple Storage Service (Amazon S3) that have open access permissions, or that allow access to any authenticated AWS user.

This check examines explicit bucket permissions, as well as bucket policies that might override those permissions. Granting list access permissions to all users for an Amazon S3 bucket is not recommended. These permissions can lead to unintended users listing objects in the bucket at high frequency, which can result in higher than expected charges. Permissions that grant upload and delete access to everyone can lead to security vulnerabilities in your bucket.

Check ID

Pfx0RwqBli

AWS Trusted Advisor Documentation, 2025

AWS Trusted Advisor

Trusted Advisor Recommendations

[Refresh all checks](#)[Download all checks](#)

Use this page to get an overview of the check results in your AWS account. Choose a check name or category to view the recommended actions or potential issues that Trusted Advisor has identified. Each check provides more information about how to address any issues. You can also download a summary of all check results. [Learn more](#)

Checks summary



Action recommended

[Info](#)



Investigation recommended

[Info](#)



Checks with excluded items

[Info](#)

AWS Trusted Advisor

2. On the **Trusted Advisor Recommendations** page, view the summary for each check category:
 - **Action recommended (red)** – Trusted Advisor recommends an action for the check. For example, a check that detects a security issue for your IAM resources might recommend urgent steps.
 - **Investigation recommended (yellow)** – Trusted Advisor detects a possible issue for the check. For example, a check that reaches a quota for a resource might recommend ways to delete unused resources.
 - **Checks with excluded items (gray)** – The number of checks that have excluded items, such as resources that you want a check to ignore. For example, this might be Amazon EC2 instances that you don't want the check to evaluate.

AWS Trusted Advisor

Trusted Advisor > Security



Trusted Advisor

Recommendations

Cost optimization

Performance

Security

Fault tolerance

Service limits

Operational excellence

▼ Preferences

Manage Trusted Advisor

Notifications

Security

Refresh all checks

Download all checks

Choose a check name to see recommendations for ways to improve the security of your AWS infrastructure. Trusted Advisor might recommend that you enable various AWS security features, close any gaps, and examine your permissions.

Checks

▶ Amazon EBS Public Snapshots

Checks the permission settings for your Amazon Elastic Block Store (Amazon EBS) volume snapshots and alerts you if any snapshots are publicly accessible.

0 EBS snapshots are marked as public.

Last updated: a few seconds ago



▶ Amazon RDS Public Snapshots

Checks the permission settings for your Amazon Relational Database Service (Amazon RDS) DB snapshots and alerts you if any snapshots are marked as public.

0 RDS snapshots are marked as public.

Last updated: a few seconds ago



▶ Amazon S3 Bucket Permissions

Checks buckets in Amazon Simple Storage Service (Amazon S3) that have open access permissions or allow access to any authenticated AWS user.

0 of 4 buckets have permission properties that grant global access.

Last updated: a few seconds ago



Check ID

Pfx0RwqBli

AWS Trusted Advisor

Alert criteria

- Yellow: The bucket ACL allows List access for **Everyone** or **Any Authenticated AWS User**.
- Yellow: A bucket policy allows any kind of open access.
- Yellow: Bucket policy has statements that grant public access. The **Block public and cross-account access to buckets that have public policies** setting is turned on and has restricted access to only authorized users of that account until public statements are removed.
- Yellow: Trusted Advisor does not have permission to check the policy or ACL, or the policy or ACL could not be evaluated for other reasons.
- Red: The bucket ACL allows upload and delete access for **Everyone** or **Any Authenticated AWS User**.
- Green: All Amazon S3 are compliant based on the ACL and/or bucket policy.



The Complexity of S3

Access Settings

S3 Security Configuration

Block Public Access (Account and Bucket)

S3 Block Public Access has 4 settings at the account level or bucket level that override access settings (ACLs and bucket policies) to limit public access to buckets.

Resource Control Policies (Org Level)

A newer type of organizational policy that can be used to limit access to resources including S3 buckets.

Object Ownership

While Object Ownership may sound unrelated, a bucket's Object Ownership settings control whether ACLs are enabled or disabled for a bucket.

Bucket Policies

Bucket Policies are a type of resource-based policy that enables usage of the IAM Policy language to grant or deny access to S3 resources.

ACLs

Amazon S3 access control lists (ACLs) enable management of access to buckets and objects. These can only be used to grant (not deny access).

Encryption

Encryption can be used as an additional form of access control. S3 encryption options include SSE-S3, KMS Encryption such as CMKs (and legacy AWS Managed Keys), and SSE-C.



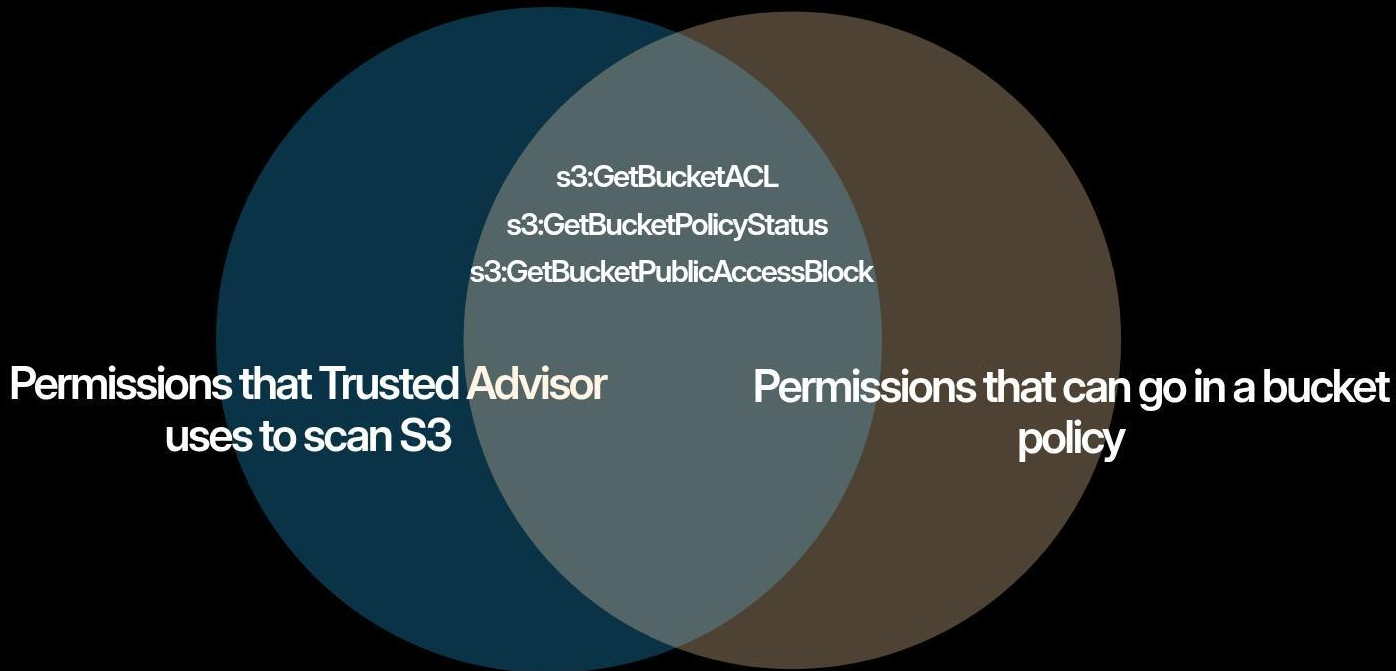
Technical Walkthrough

Finding Details: The Payload (Again)

We discovered 3 distinct scenarios where Trusted Advisor's alerting could be bypassed and would not alert on Public Buckets. This included the creation of a bucket policy that blocked Trusted Advisor from at least 1 of the following 3 actions:

- **s3:GetBucketACL**
Grants permission to use the acl subresource to return the access control list (ACL) of an Amazon S3 bucket
- **s3:GetBucketPolicyStatus**
Retrieves the policy status for an Amazon S3 bucket, indicating whether the bucket is public.
- **s3:GetBucketPublicAccessBlock**
Grants permission to retrieve the PublicAccessBlock configuration for an Amazon S3 bucket

Permission Discovery



Technical Walkthrough

Configure Bucket Policy to Deny Trusted Advisor

Create an S3 bucket policy denies Trusted Advisor the ability to check bucket BPA settings, bucket ACL settings, and/or bucket policy settings.

Configure Public Access

Set public access to the bucket via ACLs and/or bucket policies.

Bypass Trusted Advisor S3 Security Check

The Trusted Advisor S3 security check will now "ignore" the bucket. Trusted Advisor can either be manually refreshed or automatically refreshed for new results.

Evade Detection

After applying the bucket policy change, Trusted Advisor does not flag the bucket, despite the public permissions in place.

As of July 2025, this issue has been fully remediated.

Public Bucket via Policy: Example 1

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "PublicRead",
      "Effect": "Allow",
      "Principal": "*",
      "Action": "s3:GetObject",
      "Resource": "arn:aws:s3:::fwd-cloud-sec-fog-
example/*"
    }
  ]
}
```

Public Bucket via Policy: Example 2

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "PublicRead",
      "Effect": "Allow",
      "Principal": "*",
      "Action": "s3:GetObject",
      "Resource": "arn:aws:s3:::fwd-cloud-sec-fog-example/*"
    },
    {
      "Sid": "DenyTA",
      "Effect": "Deny",
      "Principal": "*",
      "Action": "s3:GetBucketAcl",
      "Resource": "arn:aws:s3:::fwd-cloud-sec-fog-example"
    }
  ]
}
```

Public Bucket via Policy: Example 3

```
{
  "Sid": "PublicRead",
  "Effect": "Allow",
  "Principal": "*",
  "Action": "s3:GetObject",
  "Resource": "arn:aws:s3:::fwd-cloud-sec-fog-example/*"
},
{
  "Sid": "DenyTA",
  "Effect": "Deny",
  "Principal": "*",
  "Action": "s3:Get*",
  "Resource": "arn:aws:s3:::fwd-cloud-sec-fog-example",
  "Condition": {
    "Bool": {
      "aws:PrincipalIsAWSService": "false"
    },
    "ArnNotLike": {
      "aws:PrincipalArn": [
        "arn:aws:iam::123412341234:role/fog-special-team/*"
      ]
    }
  }
}
```

Public Bucket via ACLs: Example 1

Access control list (ACL)

Edit

Grant basic read/write permissions to other AWS accounts. [Learn more](#)

The console displays combined access grants for duplicate grantees
To see the full list of ACLs, use the Amazon S3 REST API, AWS CLI, or AWS SDKs.

AWS doesn't recommend granting access to the Everyone grantee
Anyone in the world can access the objects in this bucket.
[Learn more](#)

Grantee	Objects	Bucket ACL
Bucket owner (your AWS account) Canonical ID:  [REDACTED]	List, Write	Read, Write
Everyone (public access) Group:  http://acs.amazonaws.com/groups/global/AllUsers	 List	 Read

Walkthrough Example

```
aws s3api put-bucket-acl --bucket fwd-cloud-sec-fog-example \\  
--grant-write uri=http://acs.amazonaws.com/groups/global/AllUsers \\  
--grant-read uri=http://acs.amazonaws.com/groups/global/AllUsers
```

```
{  
  "Sid": "PublicRead",  
  "Effect": "Allow",  
  "Principal": "*",  
  "Action": "s3:GetObject",  
  "Resource": "arn:aws:s3:::fwd-cloud-sec-fog-example/*"  
},  
{  
  "Sid": "DenyTA",  
  "Effect": "Deny",  
  "Principal": "*",  
  "Action": "s3:GetBucketAcl",  
  "Resource": "arn:aws:s3:::fwd-cloud-sec-fog-example"  
}
```


Mistrusted Advisor

S3 Bucket
Permissions

Trusted Advisor Recommendations

 Refresh all checks

 Download all checks

Use this page to get an overview of the check results in your AWS account. Choose a check name or category to view the recommended actions or potential issues that Trusted Advisor has identified. Each check provides more information about how to address any issues. You can also download a summary of all check results. [Learn more](#)

Checks summary



Action recommended
[Info](#)



Investigation recommended
[Info](#)



Checks with excluded items
[Info](#)

Mistrusted Advisor

S3 Bucket
Permissions



Amazon S3 Bucket Permissions

Checks buckets in Amazon Simple Storage Service (Amazon S3) that have op
user.

0 of 1 buckets have permission properties that grant global access. '

Last updated: 3 minutes ago



Example of an improperly reported S3 Bucket Security Check by Trusted Advisor

Mistrusted Advisor

S3 Bucket Permissions

Amazon S3 Bucket Permissions

Last updated: a few seconds ago

Checks buckets in Amazon Simple Storage Service (Amazon S3) that have open access permissions or allow access to any authenticated AWS user. Bucket permissions that grant List access can result in higher than expected charges if objects in the bucket are listed by unintended users at a high frequency. Bucket permissions that grant Upload/Delete access create potential security vulnerabilities by allowing users that to add, modify, or remove items in a bucket.

Alert Criteria

Yellow: The bucket ACL allows List access for "Everyone" or "Any Authenticated AWS User".

Yellow: A bucket policy allows any kind of open access.

Yellow: Bucket policy has statements that grant public access. The "Block public and cross-account access to buckets that have public policies" setting is turned on and has restricted access to only authorized users of that account until public statements are removed.

Yellow: Trusted Advisor does not have permission to check the policy, or the policy could not be evaluated for other reasons.

Red: The bucket ACL allows Upload/Delete access for "Everyone" or "Any Authenticated AWS User".

Green: All S3 buckets are compliant based on the ACL and/or bucket policy.

Recommended Action

If a bucket allows open access, determine if open access is truly needed. For example to host a static website, you can use Amazon CloudFront to serve the content hosted on Amazon S3. See [Restricting access to an Amazon S3 origin](#) in the CloudFront Developer Guide. When possible, update the bucket permissions to restrict access to the owner or specific users. Use Amazon S3 Block Public Access to control the settings that allow public access to your data. See [Setting Bucket and Object Access Permissions](#).

Additional Resources

[Managing Access Permissions to Your Amazon S3 Resources](#)

[Configuring block public access settings for your S3 buckets](#)

Amazon S3 Bucket Permissions (1)

Exclude & Refresh

Ignored Buckets

0 of 1 buckets have permission properties that grant global access.

< 1 > ⚙



Region Name



Region API Parameter



Bucket Name



ACL Allows List



ACL Allows Upload/Delete



Status



Policy Allows Access



fog-pub

No

No



Not evaluated (permissions)

Mistrusted Advisor (Zoom In)

S3 Bucket
Permissions

Exclude & Refresh

Included items ▲

- Included items
- Ignored Buckets
- Excluded items

ACL Allows Upload/Delete

				Exclude & Refresh		Ignored Buckets
				< 1 >		
ACL Allows List ▼	ACL Allows Upload/Delete ▼	Status ▼	Policy Allows Access			
No	No	⊖	Not evaluated (permissions)			



Issues

- **Improperly reported status of the Trusted Advisor S3 check**
 - Expected red (action recommended) result improperly reported as green (no problems detected).
 - Expected yellow (investigation recommended) result improperly reported as green (no problems detected).
- **Bucket Policy was not evaluated.**

Regardless of the permission denied, Trusted Advisor does not evaluate the bucket policy if any of the 3 permissions are denied.
- **Improperly reported ACL status**
 - Trusted Advisor displays "No" for ACL Allows List despite a public ACL that allows listing.
 - Trusted Advisor displays "No" for ACL Allows Upload/Delete despite a public ACL that allows upload/delete.
- **Bucket categorized as "ignored bucket"**

"Ignored" buckets are not evaluated as part of the overall Trusted Advisor S3 security check and do not show up in the Trusted Advisor summary dashboard.



Aftermath & Response

1 AWS has deployed updates to resolve the issue described in this blog, and all affected checks are now displaying the correct status as of June 30th, 2025. AWS has notified affected customers through their email and Health Dashboards.

2

3 As a security best practice, we recommend customers review their S3 bucket permissions and ensure they align with their security requirements. When S3 bucket policies prevent Trusted Advisor from performing certain actions ("s3:GetBucketAcl", "s3:GetPublicAccessBlock", "s3:GetBucketPolicyStatus"), customers should expect to see a "Warn" status in their Trusted Advisor check [1]. Previously, these buckets were incorrectly listed as ignored and potentially displayed incorrect status indicators for public access settings. To strengthen S3 bucket security, customers can reference our guide on blocking public access to Amazon S3 storage [2]. Customers should regularly review their Trusted Advisor security recommendations to maintain a strong security posture [1].

4

5 We appreciate Fog Security's responsible disclosure and collaboration with AWS through our Vulnerability Reporting program.

6

7 [1] <https://docs.aws.amazon.com/awssupport/latest/user/security-checks.html#amazon-s3-bucket-permissions>

8 [2] <https://docs.aws.amazon.com/AmazonS3/latest/userguide/access-control-block-public-access.html>

**AWS's
Official
Statement**

Our Take on AWS's Response

Incomplete Initial Fix

It took 2 different fixes to address the issues initially disclosed. The first fix was incomplete and did not address the inaccurate reporting on ACL status.

Insufficient Details

AWS's email communication to affected customers did not explicitly mention that Trusted Advisor inaccurately reported public buckets. The initial email also did not detail the inaccurate results listed for ACLs and potentially missed 'action recommended' (red) results.

Technical Inaccuracy

The email communication referenced `'s3:GetPublicAccessBlock,'` an incorrect permission that would not work in bucket policies. Our writeups detail `'s3:GetBucketPublicAccessBlock``.

The Fix (by AWS)

Here's what we observed.

- **Buckets are no longer ignored**

When buckets were ignored, they were not evaluated as part of the overall S3 security check. (Reminder: ignored is different than excluded)

- **ACL and Policy Status show correct information**

These now show accurate "Not evaluated (permissions)" error messages.

- **Access Error is now action recommended (Red)**

Previously, access errors were considered a investigation recommended (yellow) criteria.

- **Additional Details and Logic Change**

Trusted Advisor now shows additional details such as Block Public Access enabled.

Summary



S3 Security is Complex

With multiple different configuration options, S3 security is complex. This includes Object Ownership Settings, Block Public Access, Encryption, Object Lock, and more.

Managing S3 Access

We recommend retiring the usage of ACLs and to only use S3 bucket policies (and IAM) to control access to S3.

S3 Block Public Access

As an extra layer of security, we recommend enabling S3 BPA at both the account and bucket level where possible.

Efficacy of Security Tools

Security tools properly analyzing security configuration and reporting errors is important. We recommend ensuring your tooling reports errors. For S3, we've developed YES3 scanner, an opinionated open-source S3 scanning tool.

Layered Security

Organizational Level Controls including Resource Control Policies and Service Control Policies can help.

- **Open Source S3 Scanner: YES3 Scanner**

<https://github.com/FogSecurity/yes3-scanner>

- **Original Blog**

<https://www.fogsecurity.io/blog/mistrusted-advisor-public-s3-buckets>

- **Contact Us**

jason@fogsecurity.io

<https://www.linkedin.com/in/kaojason/>



Resources

